

Классификация данных «по-человечески»: Практическое руководство по поиску и защите критичных активов глазами Red Team

 redsec.by/article/klassifikaciya-dannyh-po-chelovecheski-prakticheskoe-rukovodstvo-po-poisku-i-zashite-kritichnyh-aktivov-glazami-red-team

Red Teams | 27 февраля 2026



Классификация данных — скучная, фундаментальная задача, которую в большинстве компаний откладывают до последнего, пока не придет жесткий аудит, регулятор или не грянет разрушительный инцидент. При этом современные организации буквально тонут в массивах неструктурированных данных. Без осознанного понимания, какие из них действительно критичны, любые меры защиты превращаются в стрельбу по воробьям из пушки.

Опираясь на многолетний опыт проведения Red Team операций и выстраивания корпоративной архитектуры безопасности, покажу, как атакующие на практике находят ваши настоящие «жемчужины» — `зарплаты.xlsx`, `клиентская_база.sql`, договора, NDA, исходные коды и прочие сокровища. Вы поймете, почему именно через призму атакующего (Offensive Security) проще всего провести по-настоящему здоровый аудит процессов управления данными и как превратить «бумажную» безопасность в реально работающий процесс.

Данный материал — это полноценное **руководство по внедрению** (Implementation Guide). Мы разберем не только методологию, но и конкретные технические

инструменты: скрипты, конфигурации, правила мониторинга и архитектурные паттерны.

Глава 1. Почему защита без классификации — самообман

Большинство стратегий кибербезопасности исторически строятся вокруг защиты периметра, патчинга уязвимостей (CVE) и внедрения очередной «серебряной пули» в виде Data Loss Prevention (DLP), Endpoint Detection and Response (EDR) или архитектуры Zero Trust Network Access (ZTNA). Однако без понимания, где живут действительно важные данные, эти дорогостоящие меры часто защищают не то, что надо, и совершенно не там, где надо.

Риски внедрения «вслепую» Попытка развернуть строгие политики DLP на весь объем корпоративных данных неизбежно приводит к параличу бизнес-процессов. Безопасники получают тысячи ложноположительных срабатываний (False Positives) в день, система переводится в режим мониторинга (Monitor Only), и реальные утечки успешно теряются в белом шуме алертов.

Исследования по защите данных и наша практическая статистика прямо указывают: классификация — это базовый, фундаментальный слой любой осмысленной программы безопасности. Она позволяет решить три критические задачи:

- **Определить ценность:** понять, какие данные критичны для выживания бизнеса, а какие вторичны.
- **Локализовать активы:** понимать, где они *реально* находятся в ИТ-ландшафте, а не где «по идее должны лежать» согласно устаревшей документации.
- **Выстроить эшелонированную защиту:** обеспечить приоритизацию контроля доступа (IAM/PAM), мониторинга (SIEM/SOC) и реагирования (IR) строго вокруг этих активов.

Без этого базиса вы либо тратите колоссальные вычислительные и человеческие ресурсы на защиту «цифрового мусора», либо, что намного хуже, оставляете по-настоящему чувствительные файлы в полудиком состоянии на общих сетевых шарах, SharePoint-сайтах и в облачных хранилищах.

Таблица 1. Сравнение подходов к защите данных

Характеристика	Традиционный подход (Периметр)	Подход, ориентированный на данные (Data-Centric)
Фокус защиты	Сети, серверы, рабочие станции	Сами файлы, базы данных, потоки информации
Понимание активов	IP-адреса, хостнеймы	Схемы данных, метки конфиденциальности
Реакция на инцидент	Блокировка порта, изоляция хоста	Отзыв прав доступа к документу, шифрование
Сложность для Red Team	Легко обходится через легитимные учетки (LotL)	Требует взлома криптографии или кражи ключей/прав

Глава 2. Что такое классификация данных «по-человечески»

В классическом (и часто неработающем) виде методологии предлагают сложные схемы с 4–6 уровнями секретности, десятками атрибутов и длинными политиками на сотни страниц, которые никто в компании не читает. На практике, особенно в условиях гибкой разработки (Agile) и распределенных команд, рабочей оказывается только упрощенная, «по-человечески» понятная модель.

Основа такой модели включает:

- **3–4 уровня важности.** Не нужно усложнять. Оптимальный набор: Публичные (Public), Внутренние (Internal), Конфиденциальные (Confidential), Критичные (Restricted/Secret).
- **Привязка к бизнес-ущербу.** Классификация строится не к абстрактной «чувствительности», а к конкретному бизнес-ущербу при утечке или порче (штрафы регуляторов, простой производства, репутационные потери, конкурентные риски, падение капитализации).
- **Связь с типами данных.** Необходимо четко указать: персональные данные (ПДн), платежная информация (PCI DSS), коммерческая тайна, интеллектуальная собственность (ИС), регуляторно значимая отчетность.

Практика общения с бизнесом

Ключевой вопрос, который удобно и нужно задавать владельцам процессов (Business Owners): *«Если завтра этот файл, таблица или база окажется в открытом доступе в Telegram-канале, что для вас сломается и сколько это*

будет стоить компании в деньгах?» Ответ на него намного продуктивнее, чем бесконечный ИБ-спор о терминах «секретно» и «строго конфиденциально».

Пример конфигурации: Автоматическая разметка (JSON)

Чтобы классификация работала, она должна поддерживаться инструментально. Ниже приведен пример конфигурации (Policy Rule) в формате JSON для Microsoft Purview (бывший Azure Information Protection), который автоматически помечает документы как «Конфиденциальные», если в них обнаруживаются паттерны номеров кредитных карт или специфические финансовые термины компании.

```
{
  "PolicyName": "Financial_Data_Auto_Labeling",
  "Description": "Автоматическая классификация документов с платежной информацией",
  "TargetLabelId": "d9f23...[REDACTED]...4a1b",
  "LabelName": "Confidential - Financial",
  "State": "Enabled",
  "Conditions": [
    {
      "Type": "SensitiveInformationType",
      "Id": "50842eb7-edc8-4019-85dd-5a5c1f2bb085",
      "Name": "Credit Card Number",
      "MinCount": 1,
      "Confidence": 85
    },
    {
      "Type": "KeywordDictionary",
      "Name": "Internal Financial Terms",
      "Keywords": ["реестр выплат", "salary_report", "EBITDA_internal", "бюджет 2026"]
    }
  ],
  "Actions": [
    {
      "Type": "ApplyLabel",
      "JustificationRequired": true
    },
    {
      "Type": "ApplyWatermark",
      "Text": "CONFIDENTIAL - DO NOT DISTRIBUTE"
    }
  ]
}
```

Глава 3. Где реально лежат «жемчужины» бизнеса

Вендоры решений по защите данных и аналитики рынка подчеркивают: наибольший риск сегодня связан именно с **неструктурированными данными** — разрозненными файлами, документами, архивами, вложениями, которые живут своей жизнью на файловых шарах, в почте и коллаборационных платформах. В таких

неконтролируемых массивах очень часто оказываются самые чувствительные сведения: договоры, платежные реестры, выгрузки из CRM, HR-отчеты со всеми ставками, сканы паспортов.

Типовые «точки концентрации» критичных данных, которые постоянно всплывают как в реальных инцидентах, так и в ходе наших оценок компрометации (Compromise Assessment):

- **Общие сетевые диски отделов:** \\fileserver\shared, \\srv\Общий, \\nas\Public, \\dc01\sysvol (где часто забывают скрипты с паролями).
- **Личные и общие папки в облаках:** Корпоративные и, что хуже, личные инстансы OneDrive, Google Drive, Box, Dropbox, куда сотрудники делают бэкапы «чтобы поработать из дома».
- **Коллаборационные платформы:** SharePoint, Confluence, Jira, внутренние Wiki-сайты, где разработчики и менеджеры выкладывают «рабочие материалы» без настройки гранулярного доступа.
- **Почтовые ящики:** Вложения в почте, в том числе бесконечные пересылки архивов с названиями вроде финал_отчет_клиенты_2022-2024.zip.
- **Тестовые среды (UAT/Dev):** Тестовые и UAT-окружения, куда ленивые DBA без маскировки (Data Masking) копируют боевые базы для разработчиков и тестировщиков.

Важно Компании, предлагающие решения для поиска и мониторинга неструктурированных данных, прямо говорят о колоссальной «слепой зоне» вокруг таких источников и острой необходимости систематического поиска и классификации на уровне файлов и документов. Если вы не сканируете свои файловые серверы, считайте, что вы не контролируете свои данные.

Практика Red Team: Поиск открытых SMB-ресурсов (Bash/Impacket)

Для атакующего поиск начинается с малого. Находясь в сети, первым делом сканируются открытые шары. Вот пример использования инструмента из арсенала Red Team (на базе Impacket) для поиска общих папок без аутентификации (Null Session) или с правами скомпрометированного рядового пользователя.

```
#!/bin/bash
# Скрипт-обертка для массового сканирования SMB шар в подсети
TARGET_SUBNET="192.168.10.0/24"
USERNAME="j.doe"
PASSWORD="Password123!"
DOMAIN="CORP"

echo "[*] Запуск перечисления SMB ресурсов в $TARGET_SUBNET..."

# Используем crackmapexec (или netexec) для поиска шар с доступом на чтение
netexec smb $TARGET_SUBNET -u $USERNAME -p $PASSWORD -d $DOMAIN --shares | grep "REA
```

```
echo "[+] Найдено доступных шар:"  
cat accessible_shares.txt
```

```
echo "[*] Поиск файлов с конфигурациями и паролями в найденных шарах..."  
# Используем spider_plus для выгрузки структуры директорий  
netexec smb $TARGET_SUBNET -u $USERNAME -p $PASSWORD -d $DOMAIN -M spider_plus -o RE
```

Глава 4. Как мыслит Red Team: сначала цель, потом уязвимость

Классический пентест (Vulnerability Assessment & Penetration Testing) часто фокусируется исключительно на уязвимостях: сканирование Nmap/Nessus, эксплуатация устаревшего софта, повышение прав, красивый отчёт с CVSS-векторами.

Red Team, работая по целям (Objective-Based Assessment), исходит из обратного: сначала формулируется «жемчужина» (что именно нужно украсть, зашифровать или исказить), а уже затем подбирается маршрут (Attack Path), инструменты и уязвимости для достижения этой конкретной цели.

На инфраструктурном уровне этот процесс выглядит так:

- **Уточнение бизнес-цели:** Получить актуальную клиентскую базу (удар по конкурентоспособности), payroll ведомости (удар по HR и внутренней стабильности), черновики M&A-сделок (инсайдерская торговля).
- **Построение карты гипотез:** Создание карты потенциальных мест хранения (CRM, ERP, файловые шары, почтовые ящики топов, облачные диски, сервисные базы, BI-отчеты).
- **Выбор векторов:** Выбор наиболее реалистичных для атакующего путей доступа — через фишинг рабочих станций пользователей, слабозащищенные внутренние веб-сервисы, перехват привилегированных аккаунтов (Kerberoasting), уязвимые тестовые среды.

Именно поэтому Red Team так болезненно и ярко высвечивает провалы в управлении данными: если команда пентестеров, обладая ограниченным временем (пара недель) и правами базового пользователя, без труда находит и забирает вашу «жемчужину», значит, это же сможет сделать и реальный злоумышленник (APT-группировка), у которого времени в запасе месяцы.

Схема атаки (Data Exfiltration Kill Chain)

- **Initial Access:** Фишинг -> Скомпрометирован хост бухгалтера.
- **Reactions & Discovery:** Запуск скриптов поиска по \\fs01\Share.
- **Collection:** Найдена база backup_1C_2025.bak с правами Everyone.

- **Exfiltration:** Упаковка в зашифрованный архив -> Отправка через DNS-туннель или легитимный API (Telegram/Google Drive).

Глава 5. Реальный поиск файлов: зарплаты.xlsx, клиентская_база.sql и прочие сокровища

Оказавшись внутри сети (через фишинг, уязвимый сервис, скомпрометированный VPN без MFA), Red Team почти всегда делает один и тот же следующий шаг: расширенную разведку файловых ресурсов и общих папок. Причем делается это не только через тяжелые автоматизированные сканеры, но и с помощью примитивного, но крайне эффективного текстового поиска по именам и содержимому. Атакующие используют технику Living off the Land (LotL) — применение штатных утилит ОС, чтобы не привлекать внимание SOC.

Типовой подход атакующих включает:

- **Перечисление (Enumeration):** Сбор информации о всех файловых шарах и SMB-ресурсах, к которым есть хоть какой-то доступ (включая скрытые шары IPC\$, C\$).
- **Таргетированный поиск по именам:** Поиск по «говорящим» именам файлов и папок: зарплаты.xlsx, salary.xlsx, pass, клиентская_база, clients.sql, договор*, contracts, NDA, паспорт*, scan_passport, 1C_выгрузка, отчет_по_клиентам.
- **Охота за расширениями (Extension Harvesting):** Поиск по маскам расширений: *.pst (локальные архивы почты, обходящие MFA), *.mdb (старые базы Access, часто содержащие пароли), *.bak, *.sql (дампы БД), *.7z, *.zip, *.xls* в общих и «личных» сетевых директориях.
- **Глубокий анализ содержимого (Deep Packet/Content Inspection):** Анализ содержимого файлов на наличие персональных данных, платежной информации, коммерческой тайны (вплоть до использования регулярных выражений для ИНН, паспортов, номеров карт, API ключей, RSA токенов).

Поставщики решений по защите неструктурированных данных раз за разом отмечают, что такого рода неуправляемые файлы с чувствительной информацией регулярно обнаруживаются в открытых для широкого круга сотрудников местах, причем без шифрования и строгих прав доступа.

Инструментарий Red Team: Автоматизированный поиск (Python)

Атакующие не проверяют файлы руками. Они используют скрипты. Ниже приведен пример концептуального Python-скрипта, который Red Team может запустить в памяти скомпрометированной машины для поиска "жемчужин" по смонтированным сетевым дискам.

```

import os
import re
import threading

# Настройки поиска
SEARCH_PATHS = ['Z:\\', 'Y:\\', '\\\\fs01\\public']
TARGET_EXTENSIONS = ['.xlsx', '.xls', '.sql', '.bak', '.txt', '.csv']
KEYWORD_REGEX = re.compile(r'(password|пароль|secret|зарплат|salary|payroll|клиент)')

# Регулярки для содержимого (PII, Кредитки)
CONTENT_REGEXES = {
    'Credit_Card': re.compile(r'\b(?:\d[ -]*?){13,16}\b'),
    'Email_List': re.compile(r'[a-zA-Z0-9._%+-]+@[a-zA-Z0-9.-]+\.[a-zA-Z]{2,}')
}

def scan_file(filepath):
    try:
        # Проверка по имени файла
        if KEYWORD_REGEX.search(filepath):
            print(f"[!] НАЙДЕН КРИТИЧНЫЙ ФАЙЛ (По имени): {filepath}")

        # Легкая проверка содержимого для текстовых форматов
        if filepath.endswith(('.txt', '.csv', '.sql')):
            with open(filepath, 'r', encoding='utf-8', errors='ignore') as f:
                content = f.read(10000) # Читаем первые 10кБ для скорости
                for label, regex in CONTENT_REGEXES.items():
                    if regex.search(content):
                        print(f"[!] НАЙДЕНЫ ДАННЫЕ ({label}): {filepath}")
                        break
    except Exception:
        pass # Игнорируем ошибки доступа, чтобы не спамить в консоль

def crawl_directory(path):
    for root, dirs, files in os.walk(path):
        for file in files:
            if any(file.endswith(ext) for ext in TARGET_EXTENSIONS):
                filepath = os.path.join(root, file)
                scan_file(filepath)

# Многопоточный запуск
threads = []
for path in SEARCH_PATHS:
    t = threading.Thread(target=crawl_directory, args=(path,))
    threads.append(t)
    t.start()

for t in threads:
    t.join()

```


Глава 6. Почему «безобидные» общие шары — главный кошмар DLP и ИБ

Основная проблема общих сетевых дисков (File Shares) и коллаборационных папок в том, что они эволюционируют в разы быстрее, чем успевают обновляться политики безопасности и списки контроля доступа (ACL). Пользователи постоянно создают подпапки, копируют архивы с боевых систем, выносят туда временные выгрузки для обработки в Excel, а затем благополучно забывают об этом навсегда.

В результате возникает токсичный эффект **«цифрового сарая»**:

- Устаревшие, но все еще бесконечно чувствительные документы продолжают лежать годами.
- Множество копий одних и тех же файлов расползается по разным шарам, десктопам и облачным дискам (нарушение принципа единого источника истины).
- **Реальные права доступа зачастую катастрофически шире**, чем это необходимо (выданы на Everyone, Domain Users, Authenticated Users, или на общую группу отдела вместо конкретных ролей).

Ошибка Архитектуры

Даже при наличии дорогих систем DLP и CASB (Cloud Access Security Broker) такие площадки часто остаются недосмотренными. Политики ИБ традиционно строятся вокруг известных систем (контроль выгрузки из CRM, мониторинг ERP, фильтрация почты), а файлы на \\fileserver\shared живут своей дикой жизнью, пока не придет Red Team — или, что фатально, следственная группа (Forensics) после публичного инцидента.

Аудит безопасности: Поиск некорректных ACL (PowerShell)

Чтобы не ждать хакеров, Blue Team (или IT-аудиторы) должны регулярно проверять права. Вот скрипт PowerShell, который находит общие папки, где группа "Все" (Everyone) имеет права на изменение или полный доступ.

```
# Скрипт для поиска избыточных прав (Everyone / Authenticated Users) на NTFS шарах
$SearchPath = "\\fs-corp\Shared"
$DangerousGroups = @("Everyone", "NT AUTHORITY\Authenticated Users", "BUILTIN\Users")

Write-Host "Сканирование ACL в директории: $SearchPath" -ForegroundColor Cyan

Get-ChildItem -Path $SearchPath -Recurse -Directory -ErrorAction SilentlyContinue |
    $folderPath = $_.FullName
    try {
        $acl = Get-Acl -Path $folderPath -ErrorAction Stop
        foreach ($access in $acl.Access) {
            if ($DangerousGroups -contains $access.IdentityReference.Value) {
                # Проверяем, есть ли права на запись/модификацию
```

```

        if ($access.FileSystemRights -match "Modify|Write|FullControl") {
            [PSCustomObject]@{
                Path          = $folderPath
                Group          = $access.IdentityReference.Value
                Permissions    = $access.FileSystemRights
            }
        }
    }
} catch {
    # Пропуск папок без прав на чтение ACL
}
} | Format-Table -AutoSize

```

Глава 7. Пентест как аудит управления данными, а не только поиск CVE

Современные методологии тестирования безопасности (например, PTES, OSSTMM, фреймворки MITRE) все чаще подчеркивают, что пентест должен использоваться не только для банального поиска уязвимостей, но и для **валидации эффективности организационных и процессных контролей**. В том числе — процессов управления данными и их классификации.

Стандарты вроде ISO 27001 (и обновленный ISO 27002:2022) прямо рассматривают результаты пентеста как важнейший вход (input) для оценки рисков и проверки работоспособности контуров ИБ, а не только как набор технических багов для патчинга. Надзорные органы в банковской сфере, финтехе и телекоме также активно включают оценку результатов тестирования и пентестов в свои чек-листы. Они ожидают, что организации смогут подтвердить не только наличие красиво оформленных политик на портале, но и **практическую защищенность** критичных активов в боевых условиях.

Таким образом, грамотно спланированный пентест или полномасштабное Red Team-упражнение превращается в мощный, эффективный инструмент аудита того, где на самом деле находятся ваши данные, кто к ним имеет технический доступ и насколько реалистично их скрытое похищение или злонамеренное искажение (Ransomware/Wiper атаки).

Глава 8. Как встроить поиск «жемчужин» в задание на пентест

Чтобы пентест работал как аудит управления данными, в его Техническое Задание (ТЗ / SOW - Statement of Work) нужно явно зафиксировать цели, связанные с поиском и оценкой защиты критичных данных. Это в корне меняет саму логику теста: от унылого списка IP-адресов под сканирование — к проверке бизнес-гипотез о местоположении и защите активов.

Чек-лист: Что включить в ТЗ (SOW)

- **Описать 3–5 ключевых видов данных:**
 - Клиентская база (ФИО, контакты, история покупок).
 - Зарплатный фонд и HR-отчетность.
 - Данные держателей карт (PAN, CVV, если применимо).
 - Конструкторская документация (CAD-чертежи, исходные коды на GitLab).
 - Стратегические финансовые планы, M&A документы.
- **Указать предполагаемые места хранения:** Укажите системы (CRM, SAP, 1C) и площадки (S3, File Shares), а также ответственные отделы — но подайте это команде пентеста **как гипотезу, а не как абсолютную истину**.
- **Поставить задачу на оценку путей (Attack Paths):** Попросить команду пентеста оценить, где эти данные находятся *фактически* (например, выгрузки в .csv на рабочем столе менеджера), какие пути к ним наиболее реалистичны в обход систем защиты, и какие средства контроля (DLP, EDR, SIEM) будут задействованы или успешно обойдены в процессе эксфильтрации.

Результаты такого теста дают бизнесу не просто скучный PDF-список технических уязвимостей со статусами "High/Medium/Low", но и **карту реального «ландшафта данных»** — с указанием конкретных мест, где классификация отсутствует или полностью не работает, а доступы и хранение грубо противоречат заявленным бумажным политикам.

Глава 9. Подход Red Team к классификации: от «крон-джуелс» к инвентаризации

В концепциях Red Team и при моделировании угроз (Threat Modeling) давно и успешно используется понятие **Crown Jewels («крон-джуелс»)** — ключевых активов корпорации, за которыми целенаправленно охотится attacker (злоумышленник). Это понятие органично и бесшовно ложится на практическую классификацию данных.

Рабочий алгоритм инвентаризации Crown Jewels выглядит так:

- **Определение:** Выделить для бизнеса 3–7 «крон-джуелс» — типов данных или систем, компрометация которых максимально болезненна (например, БД клиентов, реестр платежей, чертежи продуктов, ключевая биллинговая ИС, персональные данные в объеме выше регуляторных порогов, влекущих оборотные штрафы).
- **Оценка ущерба:** Для каждого актива определить допустимый финансовый ущерб от утечки/порчи и регуляторные/юридические последствия.
- **Гипотезы размещения:** Совместно с владельцами процессов (Business Owners) набросать гипотезы: где эти данные могут жить на практике, включая неформальные копии, бэкапы на флешках и тестовые выгрузки.

- **Практическая валидация:** На основе Red Team/пентест-упражнения жестко проверить эти гипотезы: где данные действительно лежат, какие неожиданно открытые теневые площадки всплывают, какие элементы «теневого IT» (Shadow IT) и неучтенные SaaS-сервисы всплывают в процессе поиска.

YAML-модель инвентаризации Crown Jewels (Пример для SIEM/CMDB)

Чтобы автоматизировать защиту, Crown Jewels должны быть описаны в машиночитаемом виде. Это поможет SOC-команде приоритизировать инциденты.

```
crown_jewels:
- id: CJ-001
  name: "Customer Data Warehouse"
  classification: "Restricted"
  business_owner: "VP of Sales"
  data_types:
    - "PII"
    - "Purchase History"
  approved_locations:
    - server: "db-prod-sql01.corp.local"
      path: "D:\\Databases\\CRM_Prod.mdf"
  shadow_it_risk: "High" # Часто выгружают в Excel
  monitoring:
    siem_rules:
      - "Mass_Data_Export_CRM"
      - "Unusual_Account_Access_DB"
  impact:
    financial: "High - Regulatory fines"
    reputational: "Critical"
```

В результате организация получает не мертвую академическую матрицу классификации в Word, а живую карту «критичных кладов», достоверность которой подтверждена практическим поиском атакующей стороны.

Глава 10. Инструменты и автоматизация: от ручного поиска до Data Security Posture Management

Рынок решений для поиска, классификации и защиты данных не стоит на месте и активно развивается: от простых скриптов и инструментов сканирования файловых систем до комплексных платформ **Data Security Posture Management (DSPM)** и **File Activity Monitoring (FAM)**.

Эти современные решения умеют автоматически находить чувствительные данные в публичных облаках (AWS, Azure), на локальных файловых шарах, в SaaS-сервисах (Microsoft 365, Google Workspace), применять к ним криптографические метки, строить графы доступов и генерировать сигналы для SOC.

Например, платформы управления неструктурированными данными непрерывно сканируют серверы, файловые шары, S3-совместимые хранилища и коллаборационные сервисы, чтобы находить документы с персональными данными, финансовыми сведениями, IP и другой критичной информацией. Аналогичным образом облачные инструменты классификации и Zero Trust-решения опираются на понимание того, *что именно* хранится в конкретных наборах данных, чтобы применять к ним более строгие проверки (например, требовать MFA при открытии конкретного Word-документа) и ограничивать доступ к особо чувствительным сетевым сегментам.

Важное замечание Однако даже самые продвинутые инструменты на базе ИИ и машинного обучения нуждаются в осмысленном подходе к целям сканирования и приоритизации политик. Именно это дает Red Team: сценарный взгляд злоумышленника, который подсказывает архитекторам, какие типы данных и какие неочевидные площадки стоит включить в проверку DSPM в первую очередь.

Архитектура микро-DSPM (Концепт на Go)

Для понимания того, как работают быстрые сканеры данных, вот концепт структуры воркера на Go, который конкурентно обходит директории и использует YARA-правила для классификации.

```
package main

import (
    "fmt"
    "os"
    "path/filepath"
    "sync"
    // В реальном проекте подключается go-yara
)

// Настройки сканера
const WorkerCount = 10

func fileProcessor(jobs <-chan string, results chan<- string, wg *sync.WaitGroup) {
    defer wg.Done()
    for path := range jobs {
        // Здесь логика YARA-сканирования содержимого файла
        // Имитация обнаружения:
        if filepath.Ext(path) == ".sql" || filepath.Ext(path) == ".bak" {
            results <- fmt.Sprintf("[ALERT] Незащищенный дамп БД найден: %s", path)
        }
    }
}

func main() {
```

```

targetDir := "\\fileserver\\public"

jobs := make(chan string, 1000)
results := make(chan string, 1000)
var wg sync.WaitGroup

// Запуск пула воркеров
for w := 1; w <= WorkerCount; w++ {
    wg.Add(1)
    go fileProcessor(jobs, results, &wg)
}

// Асинхронный сбор результатов
go func() {
    for res := range results {
        fmt.Println(res)
    }
}()

// Обход файловой системы
filepath.Walk(targetDir, func(path string, info os.FileInfo, err error) error {
    if err == nil && !info.IsDir() {
        jobs <- path
    }
    return nil
})

close(jobs)
wg.Wait()
close(results)
}

```

Глава 11. Как использовать выводы пентеста для улучшения классификации

После завершения пентеста или Red Team-упражнения критически важно не ограничиваться слепым исправлением конкретных уязвимостей (закрыть порт, пропатчить сервер), приведших к компрометации данных. Необходимо глубоко встроить полученные знания в процессы управления данными и их долгосрочной классификации.

Полезные и обязательные действия (Post-Engagement Mitigation):

- **Обновление реестров:** Обновить реестр информационных активов (CMDB) с учетом фактических мест хранения, выявленных в ходе теста.
- **Пересмотр уровней:** Пересмотреть уровни классификации для данных, которые оказались в значительно более уязвимых местах, чем предполагалось архитекторами (например, если ПДн постоянно выгружают в тестовую среду, возможно, нужно внедрить обязательное маскирование - Data Masking).

- **Корректировка политик ACL:** Скорректировать политики доступа и практики администрирования общих ресурсов. Это включает:
 - Минимизацию использования групп Everyone и Domain Users.
 - Физическое отделение исторических архивов от активных рабочих данных.
 - Строгий запрет хранения боевых баз в тестовых средах без маскировки и анонимизации.
- **Тюнинг SIEM:** Настройка алертов в SIEM на массовое чтение файлов с расширениями *.docx, *.xlsx с файловых шар в нерабочее время (индикатор работы программ-вымогателей или эксфильтрации).

Такая системная связка «пентест → обновление модели данных и классификации → тюнинг контролей» превращает разовый ежегодный тест в эффективный механизм постоянного улучшения (Continuous Improvement), а не просто в галочку (чекбокс) для внешнего аудита.

Глава 12. Как сделать «скуку» интересной для бизнеса

Классификация данных воспринимается топ-менеджментом и бизнесом как душная бюрократия ровно до тех пор, пока ее не удастся привязать к конкретным, наглядным историям риска и потенциальным убыткам. Пентест и результаты Red Team здесь дают ИБ-директору (CISO) идеальный, убойный материал для защиты бюджетов: скриншоты найденных файлов зарплаты.xlsx на открытом \\nas\Public, выгрузок клиентской базы на личном и общем Google Drive, незащищенных zip-архивов с паспортами сотрудников в почтовых ящиках.

Вместо показа абстрактных графиков и слайдов о «цифровых активах» и «моделях угроз», ИБ-команда может показать совету директоров следующее:

- **Реальный Attack Path:** Реальный путь атакующего от клика бухгалтера по фишинговому письму до компрометации контроллера домена и полного скачивания файла клиентская_база.sql.
- **Демонстрация хаоса:** Реальный набор общих папок, где лежат стратегические договоры и финансы с правами на чтение у половины компании (включая стажеров и подрядчиков).
- **Крушение иллюзий:** Реальную несостыковку между декларируемыми бумажными политиками (статус "строго конфиденциально", доступ "только по роли") и тем, как всё устроено в живой инфраструктуре.

Такой профессиональный сторителлинг превращает «нудную классификацию» в живой, эмоциональный разговор о деньгах, личной ответственности руководителей и репутации бренда, а не о скучных метках на документах.

Вывод: пентест как лучший инструмент для аудита управления данными

В 2020-е годы объемы корпоративной информации и сложность гибридных ИТ-ландшафтов достигли такого уровня, что любые попытки защитить «все подряд» одинаково надежно обречены на провал. Финансовые и человеческие ресурсы ИБ ограничены, а атакующие всегда выбирают самые простые пути к самым ценным целям (Path of Least Resistance).

Поэтому единственный практичный подход к безопасности сегодня — сначала скрупулезно разобраться, где и как живут ваши настоящие «жемчужины», а уже потом строить вокруг них дорогую эшелонированную оборону (Defense-in-Depth).

Интеграция подходов Red Team и проведение пентестов, сфокусированных на данных, дают именно то, чего критически не хватает оторванным от реальности кабинетным моделям классификации:

- **Видимость:** Реальную карту фактического расположения ключевых активов и "теневого ИТ".
- **Проверку боем:** Проверку жизнеспособности политик и технических контролей с точки зрения недружелюбного и квалифицированного атакующего.
- **Бизнес-аргументацию:** Наглядный, неопровержимый материал, который убеждает бизнес в необходимости инвестиций и изменений в процессах.

Используя пентест не только как рутинный «поиск CVE» для ИТ-отдела, но и как мощный инструмент аудита управления данными, организация получает шанс наконец-то сделать классификацию не формальной галочкой в отчете комплаенса, а живым, практичным механизмом защиты того, что для нее действительно ценно.

FAQ: Часто задаваемые вопросы

1. С чего начать классификацию данных, если в компании петабайты неструктурированной информации? Начните с инвентаризации "Crown Jewels" — 3-5 самых критичных типов данных (например, ПДн и исходные коды). Используйте скрипты или DSPM-системы для сканирования только этих паттернов в самых очевидных местах (общие сетевые диски, SharePoint). Не пытайтесь сразу классифицировать всё.

2. Может ли DLP-система заменить ручную классификацию и DSPM? Нет. DLP-системы отлично контролируют каналы передачи данных (веб, почта, USB), но они слепы к данным в состоянии покоя (Data at Rest), если к ним не применены агенты сканирования (Data Discovery). Без классификации DLP будет генерировать огромное количество ложных срабатываний.

3. Как правильно прописать поиск "жемчужин" в договоре на пентест? Сделайте это отдельным этапом в Statement of Work (SOW). Назовите его "Data Exfiltration & Objective-based testing". Укажите, что пентестеры должны продемонстрировать возможность доступа к конкретным типам данных (например, выгрузке 1С), минуя средства контроля.

4. Какие инструменты использует Red Team для поиска данных в нашей сети?

Помимо кастомных скриптов (Python, PowerShell), активно используются инструменты: Snaffler (для поиска секретов на шарах), BloodHound (для поиска путей до серверов с данными), Seatbelt (анализ локальных секретов) и штатные утилиты Windows (Findstr, PowerShell).

5. Что делать, если пентестеры нашли критичные данные на общей файловой шаре?

Первым делом — изолировать данные, изменив ACL (оставив доступ только владельцам). Затем провести мини-расследование: как данные туда попали (нарушение процесса или злой умысел). И в конце — настроить автоматический мониторинг (FSRM или DSPM) на появление подобных файлов в этой директории в будущем.

6. Как часто нужно пересматривать классификацию данных? На уровне политик — ежегодно. На техническом уровне (сканирование шар и облаков) — это должен быть непрерывный процесс (Continuous Discovery), так как новые файлы и проекты создаются ежедневно.

7. Помогает ли шифрование (Full Disk Encryption) от кражи данных внутренним нарушителем?

FDE (например, BitLocker) защищает только от физической кражи диска или ноутбука. Если атакующий или инсайдер вошел в систему под своей учетной записью или удаленно эксплуатировал уязвимость при включенном ПК, FDE абсолютно бесполезен — ОС отдает файлы в расшифрованном виде. Здесь нужна защита на уровне файлов (Rights Management) и ACL.

8. Являются ли тестовые среды (UAT, Dev) целью для Red Team? Да, это одна из

любимейших целей. В тестовых средах часто используются слабые пароли, отключены антивирусы, но при этом там лежат полные дампы боевых баз данных. Защита тестовых сред и обязательное маскирование (обфускация) данных перед переносом из Prod в Dev — критически важный шаг.